

Managementul cheilor criptografice

Ion BICA, PhD, CISA

ion.bica@mta.ro

Obiective

- Analiza principalelor aspecte referitoare la managementul cheilor criptografice
- Prezentarea de recomandări cu privire la alegerea algoritmilor criptografici și selectarea lungimilor de chei
- Înțelegerea rolului unei Infrastructuri de Chei Publice (PKI) și a elementelor componente
- Acumularea cunoștințelor necesare proiectării și implementării de PKI-uri organizaționale

Conținut

1. Aspecte privind managementul cheilor criptografice
2. Infrastructuri de chei publice

Bibliografie

- William Stallings, “Cryptography and Network Security, 5/E”, Prentice Hall, 2011
- Niels Ferguson, Bruce Schneier, “Practical Cryptography”, Wiley Publishing, 2003
- Victor Patriciu, Monica Pietroșanu, Ion Bica, Iustin Priescu, “Semnături electronice și securitatea informatică”, Editura All, 2006
- Resurse disponibile pe Internet

Detalii organizatorice

- Număr de ore: 14
- Examen
 - test grilă
- Informațiile aferente cursului vor fi disponibile în format electronic
 - note de curs / laborator
 - documentație auxiliară



1. Aspecte privind managementul cheilor criptografice

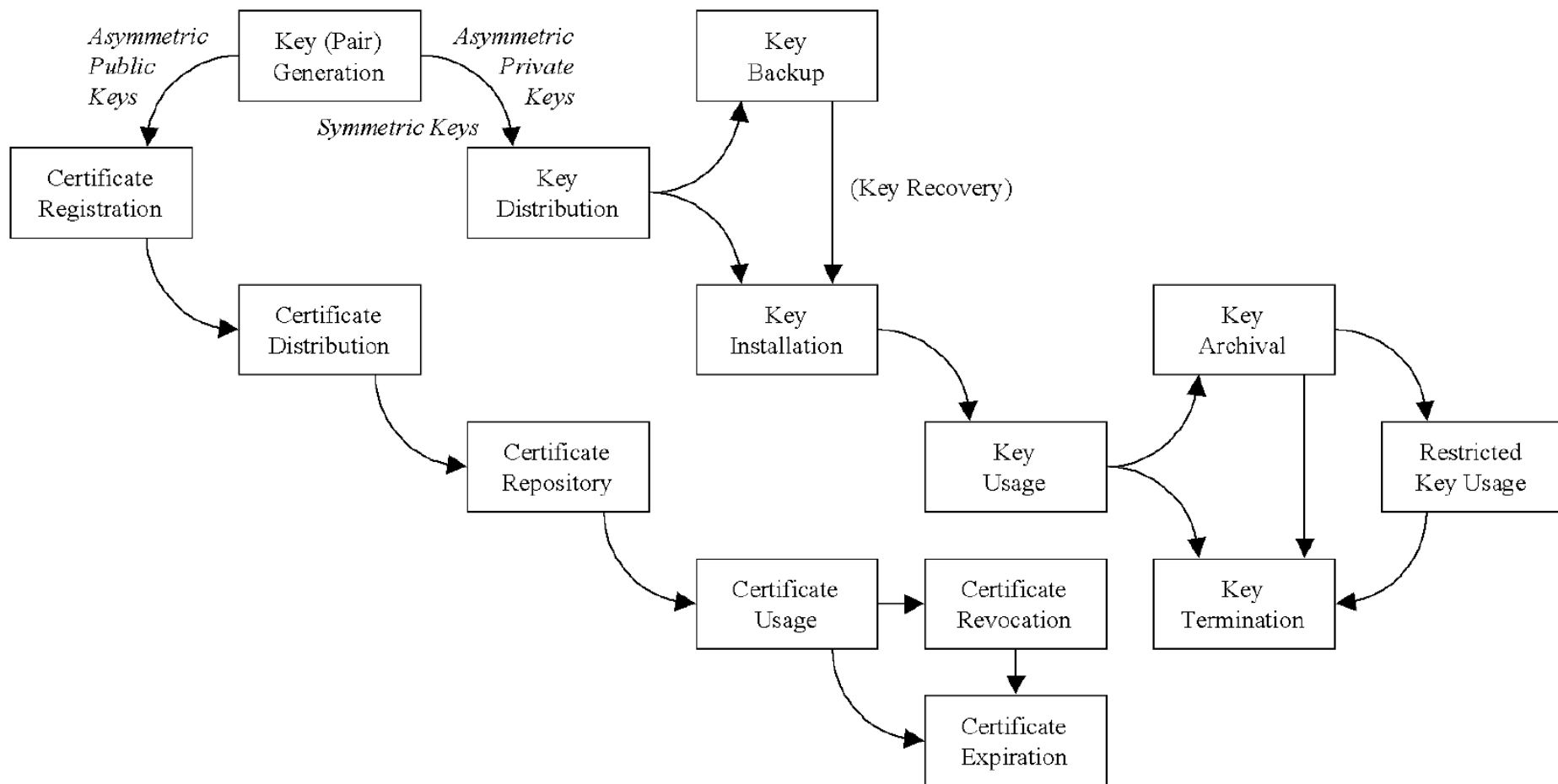
Managementul cheilor criptografice

- Securitatea unui sistem criptografic depinde în mare parte de modul în care se realizează managementul cheilor
 - cel mai sigur seif din lume nu valorează nimic atunci când combinația de numere necesară deschiderii seifului a fost aflată de adversar
- Aspect specific implementării practice a sistemelor criptografice
 - pot apare erori atât în partea de implementare cât mai ales în partea de exploatare
- Cauza pentru care multe sisteme criptografice au fost “sparte”
- Greu să nu faci greșeli atâta timp cât factorul uman joacă un rol foarte important în acest proces

Managementul cheilor criptografice (cont.)

- Managementul cheilor = administrarea sigură a cheilor criptografice pe tot parcursul ciclului de viață al acestora
- Managementul cheilor simetrice
- Managementul cheilor publice/private
 - Infrastructuri de Chei Publice (PKI)
- Pentru toate tipurile de chei trebuie asigurată integritatea
- Cheile secrete și cele private trebuie protejate împotriva dezvăluirii neautorizate

Ciclul de viață al cheilor criptografice



Generarea cheilor

- Generatoare de numere aleatoare
 - pe un sistem de calcul este imposibil să se genereze numere complet aleatoare (John von Neumann) – nr. de stări ale sistemului este finit
 - pentru a obține un grad ridicat de securitate trebuie ca numerele generate să nu poată fi prezise sau reproduse
- Generatoare deterministe (pseudoaleatoare)
 - folosesc un algoritm pentru a genera numere pseudoaleatoare (FIPS 186-3)
- Generatoare non deterministe
 - surse fizice: zgomotul termic al tranzistoarelor, contoare Geiger-Muller, zgomot radio, etc

Distribuția cheilor

- Cea mai critică operație!
- Sisteme criptografice simetrice
 - curier de încredere (valiza diplomatică)
 - Quantum Key Distribution
- Sisteme criptografice cu chei publice
 - Certificate digitale
 - Cum se distribuie certificatele autorităților rădăcină?

Instalarea cheilor

- Pe disk, în fișiere
 - Criptate cu parolă (PKCS #12)
 - Acces restricționat de către sistemul de operare
- Pe dispozitive criptografice
 - Hardware Security Module (HSM)
 - Smart Card, USB dongle (token)

Salvarea / Restaurarea cheilor

- Se salvează doar cheile de decriptare a datelor
 - refacerea datelor în cazul pierderii chei
 - accesul la date în caz de nevoie (key escrow)
- Sisteme speciale care să asigure atât integritatea cât și controlul accesului
 - scheme “m din n” pentru accesul la chei
- Cheile de semnătură nu trebuie salvate!
 - se pierde caracterul de non-repudiere al semnăturilor

Utilizarea cheilor

- Încărcarea cheilor în memorie
 - ștergerea zonei după dealocare
- Autentificarea fiecărui acces
- Interfețe utilizator de încredere
 - key loggers
 - fake interfaces

Arhivarea cheilor

- Sisteme speciale care să asigure atât integritatea cât și controlul accesului
- Amprente de timp asociate fiecărei chei introduse în arhivă
- Cheile arhivate nu trebuie folosite niciodată în producție!

Ștergerea (terminarea) cheilor

- Ștergerea datelor de pe mediile de stocare nu este simplă!
 - comanda de ștergere a unui fișier marchează spațiu ocupat de fișierul respectiv ca fiind liber
 - alinierea capetelor de citire / scriere la un hard disc nu este perfectă
- Algoritmi speciali de ștergere a datelor (wipe)
 - suprascrierea repetată cu valori aleatoare
- Cheile trebuie șterse imediat ce nu mai este nevoie de ele

Algoritmi criptografici recomandați

- Funcții hash
 - SHA-2 (224, 256, 384, 512 biți)
 - SHA-3 (Keccak)
- Algoritmi simetrici
 - AES - lungime bloc date 128 biți, lungime cheie 128, 256 biți
 - TDEA (3DES) - lungime bloc date 64 biți, lungime cheie 3x56 biți
- Algoritmi cu chei publice (asimetrice)
 - Semnături digitale
 - RSA, DSA, ECDSA
 - Schimbul de chei
 - DH, anvelopare RSA

Lungimea cheilor

- “Spargerea” DES-ului prin forță brută
 - Electronic Frontier Foundation, 1998
 - DES Deep Crack, peste 90 miliarde chei pe secundă
 - 4.5 zile pentru a sparge o cheie DES de 56 biți
 - distributed.net, 1999
 - 250 miliarde chei pe secundă
- Dificultatea unui atac prin forță brută crește exponențial cu lungimea cheii!

Lungimi de chei recomandate

Date	Security Strength	Symmetric Algorithms	Factoring Modulus	Discrete Logarithm Key Group	Elliptic Curve	Hash (A)	Hash (B)
Legacy	80	2TDEA	1024	160 1024	160	SHA-1	
2019 - 2030	112	(3TDEA) AES-128	2048	224 2048	224	SHA-224 SHA-512/224 SHA3-224	
2019 - 2030 & beyond	128	AES-128	3072	256 3072	256	SHA-256 SHA-512/256 SHA3-256	SHA-1 KMAC128
2019 - 2030 & beyond	192	AES-192	7680	384 7680	384	SHA-384 SHA3-384	SHA-224 SHA-512/224 SHA3-224
2019 - 2030 & beyond	256	AES-256	15360	512 15360	512	SHA-512 SHA3-512	SHA-256 SHA-512/256 SHA-384 SHA-512 SHA3-256 SHA3-384 SHA3-512 KMAC256

<https://www.keylength.com/en/>

Best practices

- Conștientizarea utilizatorilor de importanța gestiunii corecte a cheilor criptografice
 - responsabilități și implicații posibile
- Elaborarea unui plan care să trateze cazul în care cheile au fost compromise
 - planul trebuie să existe înainte ca sistemul să devină operațional
- Folosirea de algoritmi și module criptografice validate
 - FIPS 140-2 Level 1 / 2 / 3

Best practices (cont.)

- În general, o cheie trebuie folosită doar într-un singur scop (criptare, semnare, etc)
- Cheile trebuie schimbate cât mai des posibil
- Se recomandă ca stocarea cheilor să se facă pe dispozitive criptografice (HSM, smart cards, etc)

Referințe

- ENISA – “Algorithms, Key Sizes and Parameters Report, 2014 Recommendations”
- NIST SP 800-57 - “Recommendation for Key Management”, Part 1
- A. J. Halderman, “Lest We Remember: Cold Boot Attacks on Encryption Keys”, 2008
- D. Genkin, “RSA Key Extraction via Low-Bandwidth Acoustic Cryptanalysis”, 2014



2. Infrastructuri de Chei Publice (PKI)

Criptografia cu chei publice

- Fundamentul serviciilor de securitate
 - autentificare
 - confidențialitate
 - integritate
 - non-repudiere
- Fiecare entitate dispune de o pereche de chei:
 - cheie publică
 - cheie privată
- Problema: distribuirea cheilor publice?
 - mecanism care să asigure că o cheie publică aparține unei entități
- Soluția: Infrastructuri de Chei Publice (PKI)
 - certificate digitale de chei publice

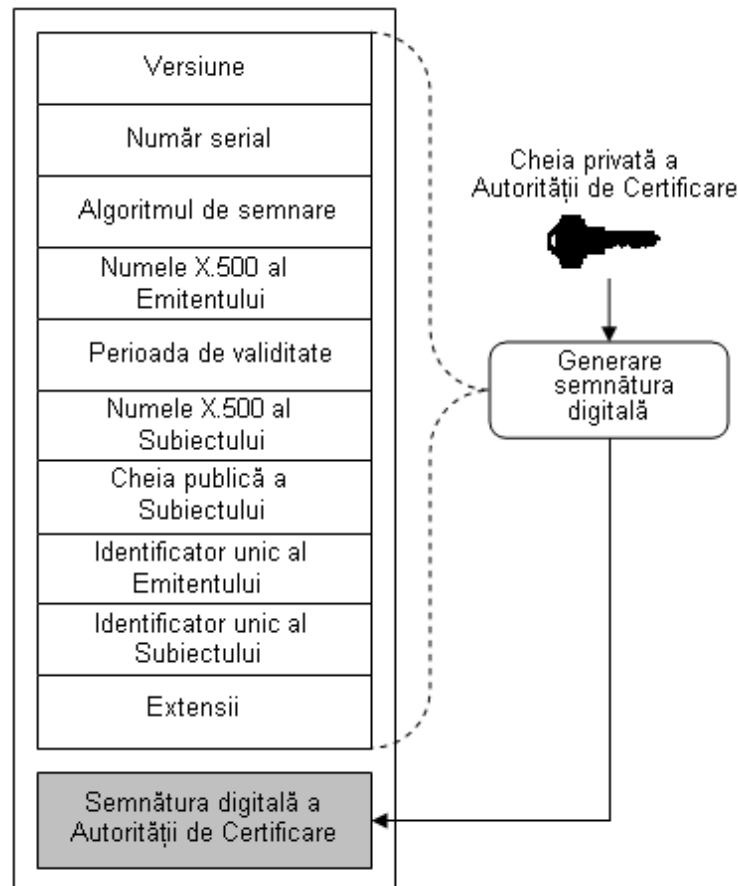
Certificate digitale

- Certificat digital = legătură imposibil de falsificat dintre o cheie publică și un atribut al posesorului acesteia
- Structură de date ce conține valoarea chei publice și o serie de informații de identificare unice
- Emis de către o Autoritate de Certificare (AC)
 - terț de încredere
 - AC certifică autenticitatea datelor din certificat
 - certificatele digitale sunt semnate de către AC (pentru a asigura integritatea și autenticitatea acestora)

Certificate digitale (cont.)

- Concept introdus pentru prima dată de L. Kohnfelder, 1978
- ITU-T – Recomandările X.509
 - versiunea 1 (1988), 2 (1993), 3 (1997, 2000)
- IETF PKIX – RFC 3280, RFC 5280 (Certificate and Certificate Revocation List (CRL) Profile)
- RFC 3039, RFC 3739 (Qualified Certificates Profile)
- ETSI TS 101 862

Certificate digitale X.509 v3



Certificate digitale X.509 v3 (cont.)

- *Versiunea (Version)*
 - versiunea formatului de certificat (1, 2 sau 3)
- *Numărul serial (Serial Number)*
 - identificator numeric unic al certificatului relativ la mulțimea tuturor certificatelor emise de Autoritatea de Certificare
- *Algoritmul de semnare (Signature Algorithm)*
 - algoritmul folosit de Autoritatea de Certificare pentru semnarea certificatului
 - identificarea algoritmului se face folosind identificatori de obiect (OID – Object Identifier)
 - exemplu: sha1withRSAEncryption 1.2.840.113549.1.1.5
- *Numele X.500 al Emitentului (Issuer X.500 Name)*
 - numele distinct (DN – Distinguished Name) al Autorității de Certificare
 - exemplu: “CN=ABC Root CA, O=ABC, C=RO”
- *Perioada de validitate (Validity Period)*
 - intervalul de timp pe parcursul căruia certificatul poate fi considerat valid (dacă nu cumva a fost revocat între timp)

Certificate digitale X.509 v3 (cont.)

- *Numele X.500 al Subiectului (Subject X.500 Name)*
 - numele distinct (DN – Distinguished Name) al proprietarului certificatului
 - exemplu: “CN=Ion Bica, O=ABC, C=RO”
- *Cheia publică a Subiectului (Subject Public Key Info)*
 - valoarea cheii publice a subiectului precum și identificatorul algoritmului cu care acesta poate fi folosită (de exemplu, RSA, DSA sau Diffie-Hellman)
- *Identificatorul unic al Emitentului (Issuer Unique Identifier)*
 - identificator unic al Autorității de Certificare
 - rar întâlnit în implementările practice iar RFC 3280 nu recomandă folosirea lui
- *Identificatorul unic al Subiectului (Subject Unique Identifier)*
 - identificator unic al proprietarului certificatului
 - rar întâlnit în implementările practice iar RFC 3280 nu recomandă folosirea lui
- Extensii
 - câmp opțional, introdus odată cu versiunea 3 de certificate
 - adăugarea de attribute suplimentare la certificat
 - format standard: (tip, critică/necritică, valoare)

Extensii standard

- *Identificatorul cheii autorității (Authority Key Identifier)*
 - *Identificatorul cheii subiectului (Subject Key Identifier)*
 - *Modul de utilizare al cheii (Key Usage)*
 - *Modul extins de utilizare a cheii (Extended Key Usage)*
 - *Punctul de distribuție a CRL (CRL Distribution Point)*
 - *Perioada de utilizare a cheii private (Private Key Usage Period)*
 - *Politicile de certificare (Certificate Policies)*
 - *Mapări de politici (Policy Mappings)*
 - *Nume alternativ al Subiectului (Subject Alternative Name)*
 - *Nume alternativ al Emitentului (Issuer Alternative Name)*
 - *Atribute de director ale Subiectului (Subject Directory Attributes)*
 - *Constrângeri de bază (Basic Constraints)*
 - *Constrângeri de nume (Name Constraints)*
 - *Constrângeri de politică (Policy Constraints)*
 - *Anularea oricărei politici (Inhibit Any Policy)*
 - *Pointer către cel mai recent CRL (Freshest CRL Pointer)*
-
- *Modul de acces la informațiile despre Autoritate (Authority Information Access) - RFC 3280*
 - *Modul de acces la informațiile despre Subiect (Subject Information Access) - RFC 3280*

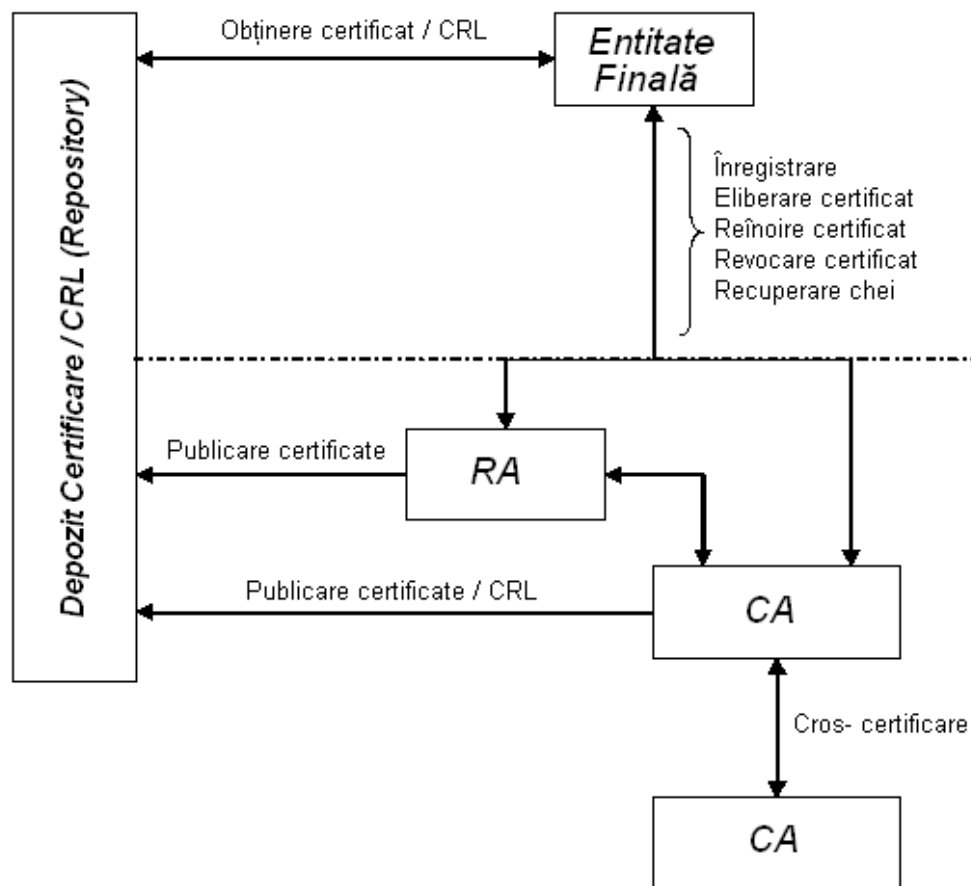
Alte tipuri de certificate

- Certificate SPKI (SPKI – Simple Public Key Infrastructure)
 - certificate de autorizare
- Certificate PGP (PGP – Pretty Good Privacy)
 - Web of Trust
- Certificate de atribut
 - gestiunea privilegiilor (PMI - Privilege Management Infrastructure)

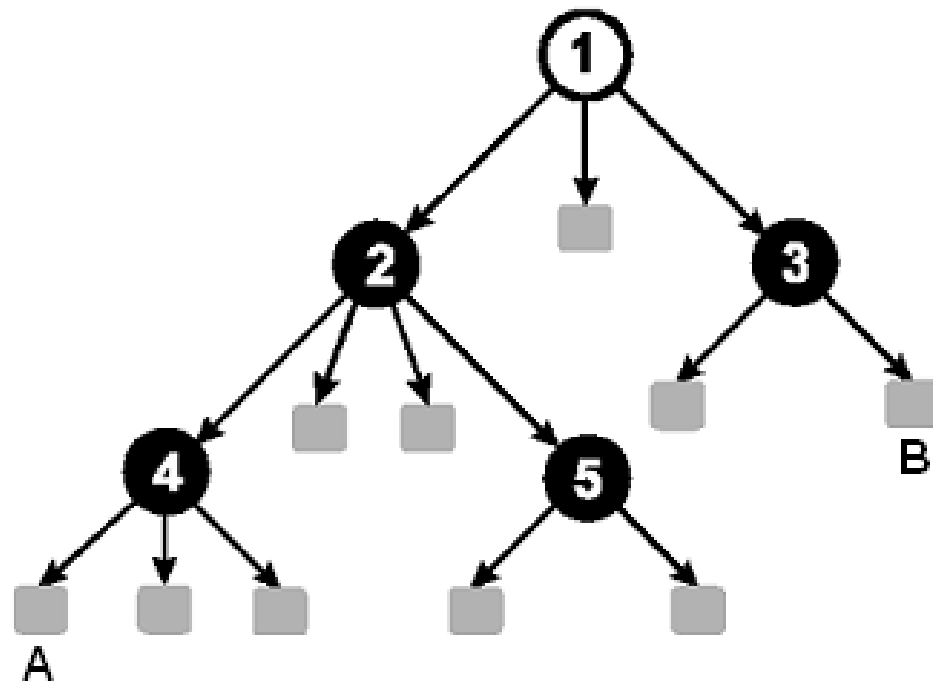
PKI

- Managementul certificatelor digitale
- PKI = {politici, proceduri, software, hardware, personal}
- Componente PKI:
 - *Autoritățile de Certificare* (CA – Certification Authority)
 - *Autoritățile de Înregistrare* (RA – Registration Authority)
 - *Depozitele de certificate* (Repository)
 - *Entitățile Finale* (End Entity)

Modelul arhitectural PKIX



Arhitecturi ierarhice

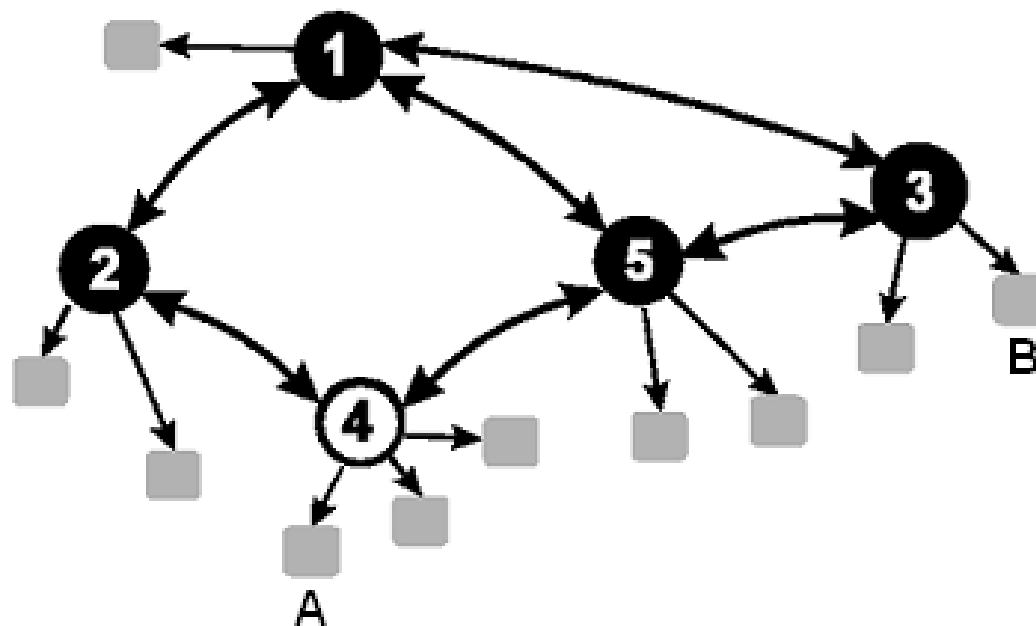


$B \rightarrow AC_3 \rightarrow AC_1$

Arhitecturi ierarhice (cont.)

- Avantaje:
 - se mapează destul de bine pe structura ierarhică a organizațiilor
 - căile de certificare sunt unidirecționale și ușor de determinat
 - căile de certificare sunt relativ scurte
 - scalabilitate ridicată
 - ierarhizarea numelor entităților
- Dezavantaje:
 - compromiterea root-ului duce la compromiterea întregii infrastructuri
- Majoritatea aplicațiilor PKI actuale oferă suport numai pentru acest tip de arhitectură!

Arhitecturi de tip rețea



$B \rightarrow AC_3 \rightarrow AC_5 \rightarrow AC_4$

$B \rightarrow AC_3 \rightarrow AC_1 \rightarrow AC_2 \rightarrow AC_4$

$B \rightarrow AC_3 \rightarrow AC_1 \rightarrow AC_5 \rightarrow AC_4$

Arhitecturi de tip rețea (cont.)

- Avantaje:
 - flexibilitate ridicată în asigurarea interoperabilității
 - model de încredere natural
 - cross-certificare directă între AC
 - compromiterea cheii private a unei autorități nu afectează celelalte autorități
- Dezavantaje:
 - construirea căilor de certificare este complicată
 - căile de certificare sunt dependente de utilizatorul care face validarea (nu se pot face optimizări)

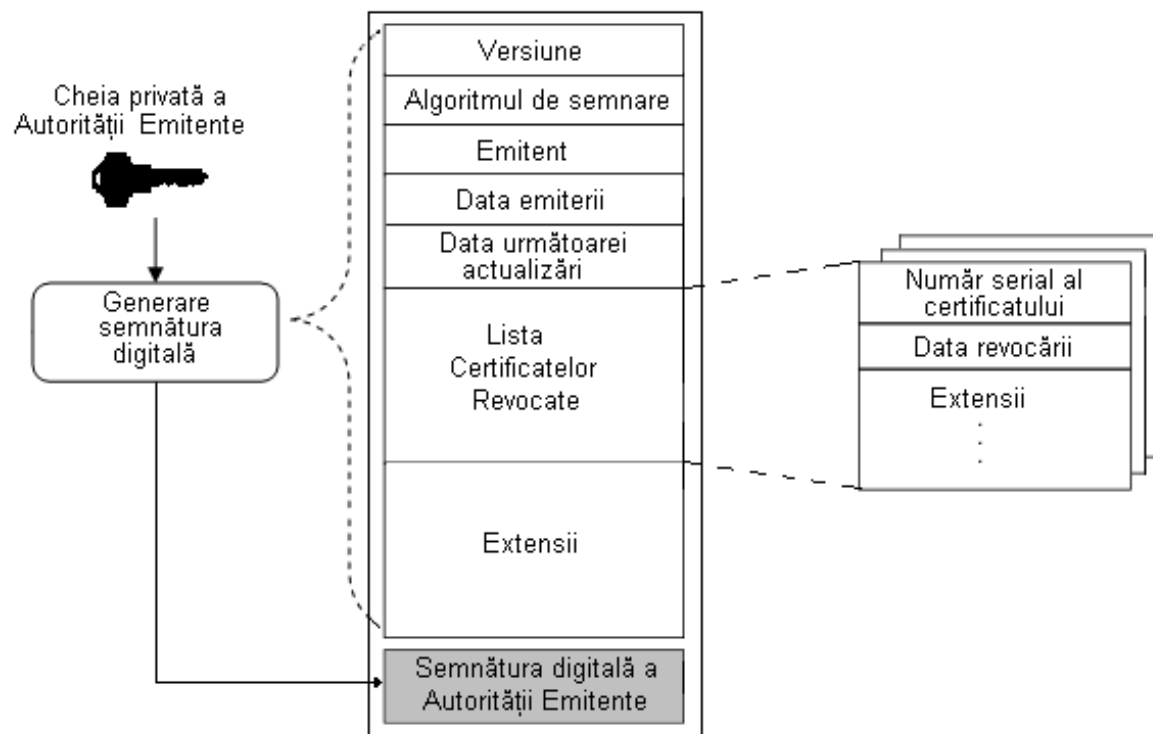
Politicele și practicile de certificare

- Cum se determină încrederea într-o autoritate de certificare?
 - operarea în conformitate cu niște politici și proceduri clar stabilite
 - auditarea de către o terță parte
- Politica de Certificare (CP – Certificate Policy)
- Declarația privind Practicile de Certificare (CPS – Certification Practices Statement)
- Elaborate de regulă de către Autoritățile pentru Gestiunea Politicilor (PMA – Policy Management Authorities)
- OID -uri de politică
- RFC 2527, RFC 3647 (Certificate Policy and Certification Practices Framework)
- ETSI TS 101 456 (Policy requirements for certification authorities issuing qualified certificates)
 - QCP public + SSCD
 - QCP public
- Asigurarea interoperabilității între domenii PKI diferite

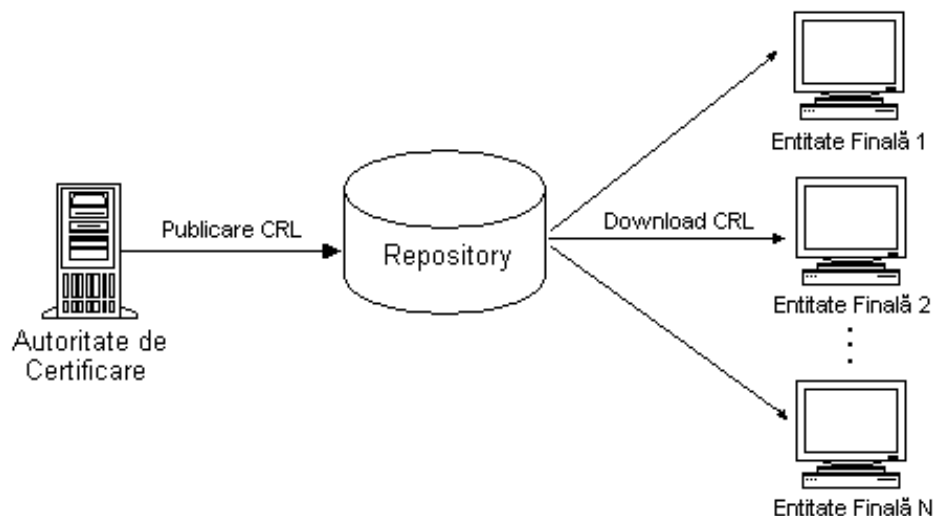
Validarea stării certificatelor

- Starea unui certificat: valid, revocat, expirat
- Revocarea certificatelor:
 - compromiterea / pierderea cheii private
 - schimbarea numelui subiectului
 - părăsirea organizației
- Mecanisme care să permită determinarea stării de revocare a certificatelor
 - Liste de certificate revocate (CRL)
 - Protocoale online (OCSP)

CRL

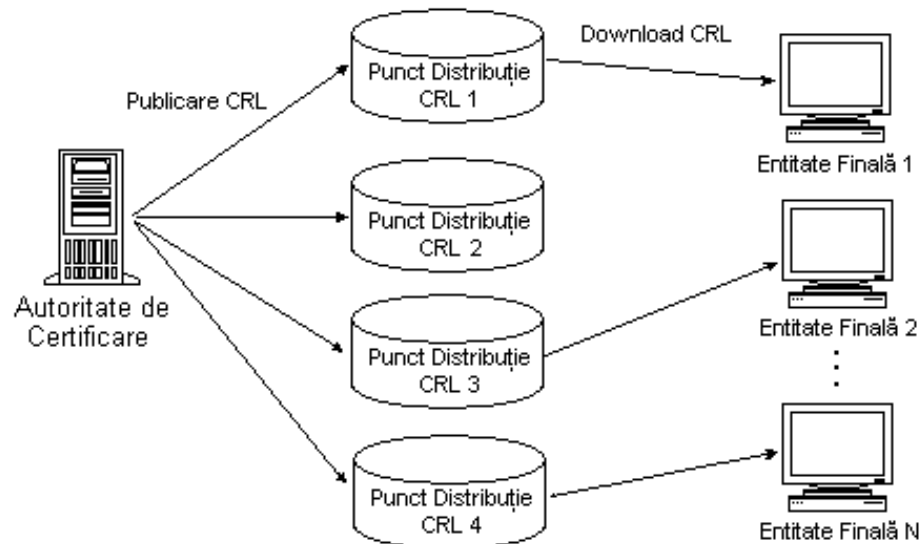


CRL (cont.)



- Odată downloadat, CRL-ul va fi folosit din cahe-ul local până expiră
- Exactitatea schemei depinde de perioada de publicare a CRL-urilor
- Trebuie găsit un optim între perioada de publicare a CRL-urilor și încărcarea rețelei
- Supra-emiterea de CRL-uri

Puncte de distribuție a CRL-urilor



- Extensia *CRLDistributionPoints* din cadrul certificatelor
 - locațiile de la care se poate descărca CRL-ul pe baza căruia se determină starea certificatului
 - din motive de disponibilitate, se recomandă ca publicarea CRL-urilor să se facă în mai multe locații

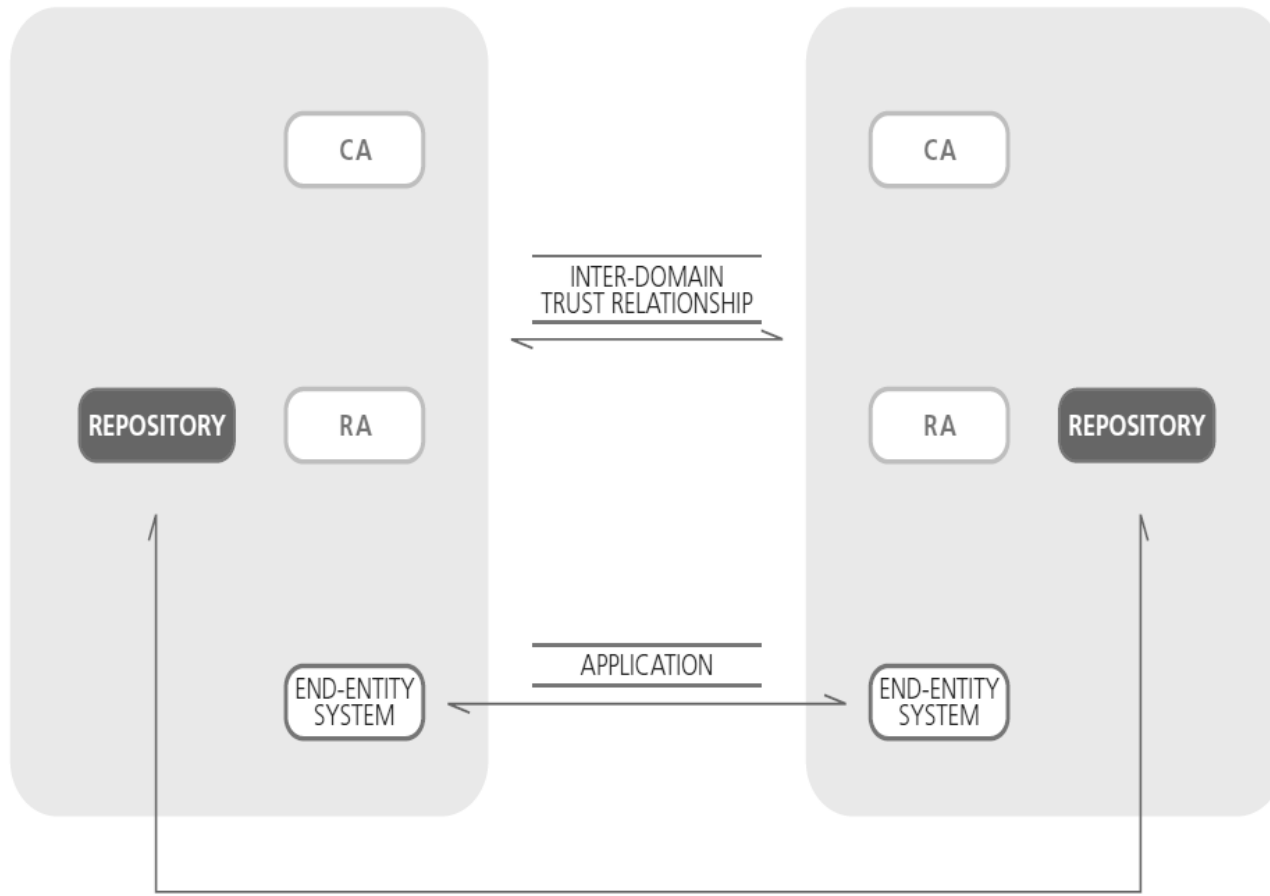
Delta CRL

- Creșterea preciziei
- Conține toate certificatele revocate după publicarea unui CRL de bază
- Delta CRL-urile sunt publicate la intervale mici de timp
- Pentru a determina cu precizie starea unui certificat, o aplicație are nevoie de CRL-ul de bază și cel mai recent delta CRL
- Extensia *deltaCRLIndicator* (folosită pentru a face distincție între un CRL de bază și un delta CRL)

OCSP

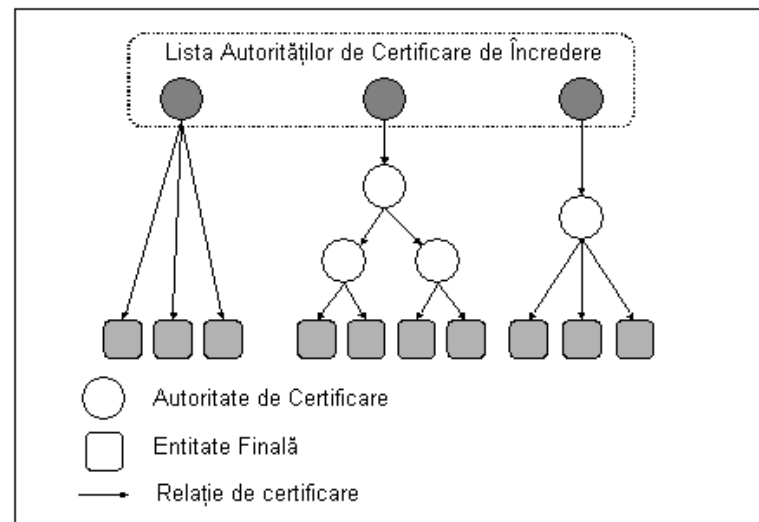
- Protocol simplu de tip cerere/răspuns
 - Client OCSP
 - Responder OCSP
- RFC 2560
- Parte integrantă a unei AC sau independente
- Determinarea stării certificatelor:
 - interogarea directă a bazei de date a AC
 - procesarea CRL-urilor emise de AC
 - transmiterea cererii către un alt responder OCSP
- Răspunsuri OCSP: good, revoked, unknown

Interoperabilitatea PKI



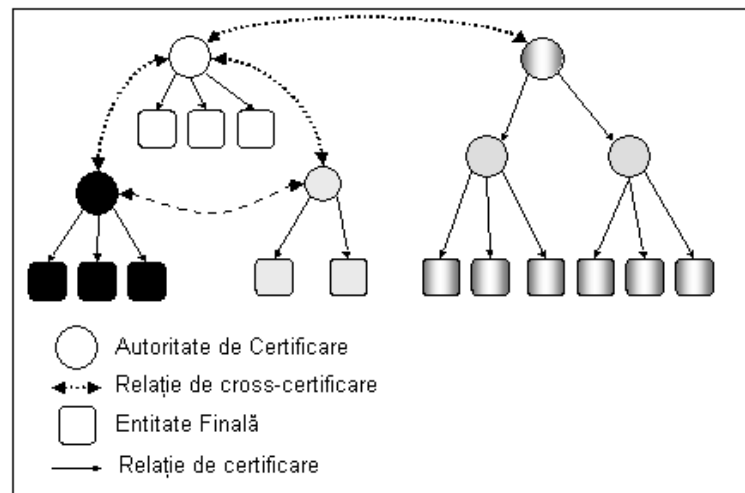
Liste de AC de încredere

- Cea mai folosită soluție
- Greu de gestionat
- Microsoft Windows
2000/2003/2008/2012/2016
 - Certificate Trust List (CTL)
 - digitally signed



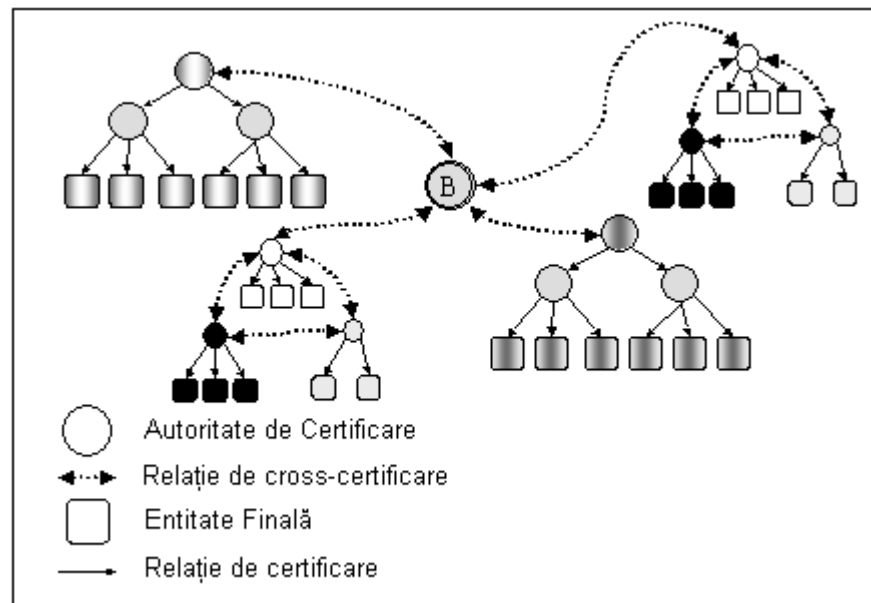
Cross-certificarea

- Relații de încredere reciproce
- Limitarea extinderii
 - constrângeri de nume
 - constrângeri de politică
 - constrângeri privind lungimea căilor de certificare
- Scalabilitate scăzută
 - $n*(n-1) / 2$ relații de cross-certificare!



Autorități de Certificare Punte (Bridge CA)

- Simplifică procesele de echivalare a politicilor de certificare
- BCA nu trebuie declarată ca fiind de încredere!
- Exemple:
 - Federal (BCA)
 - Higher Education BCA (HEBCA)
 - SAFE Bridge CA (SBCA)



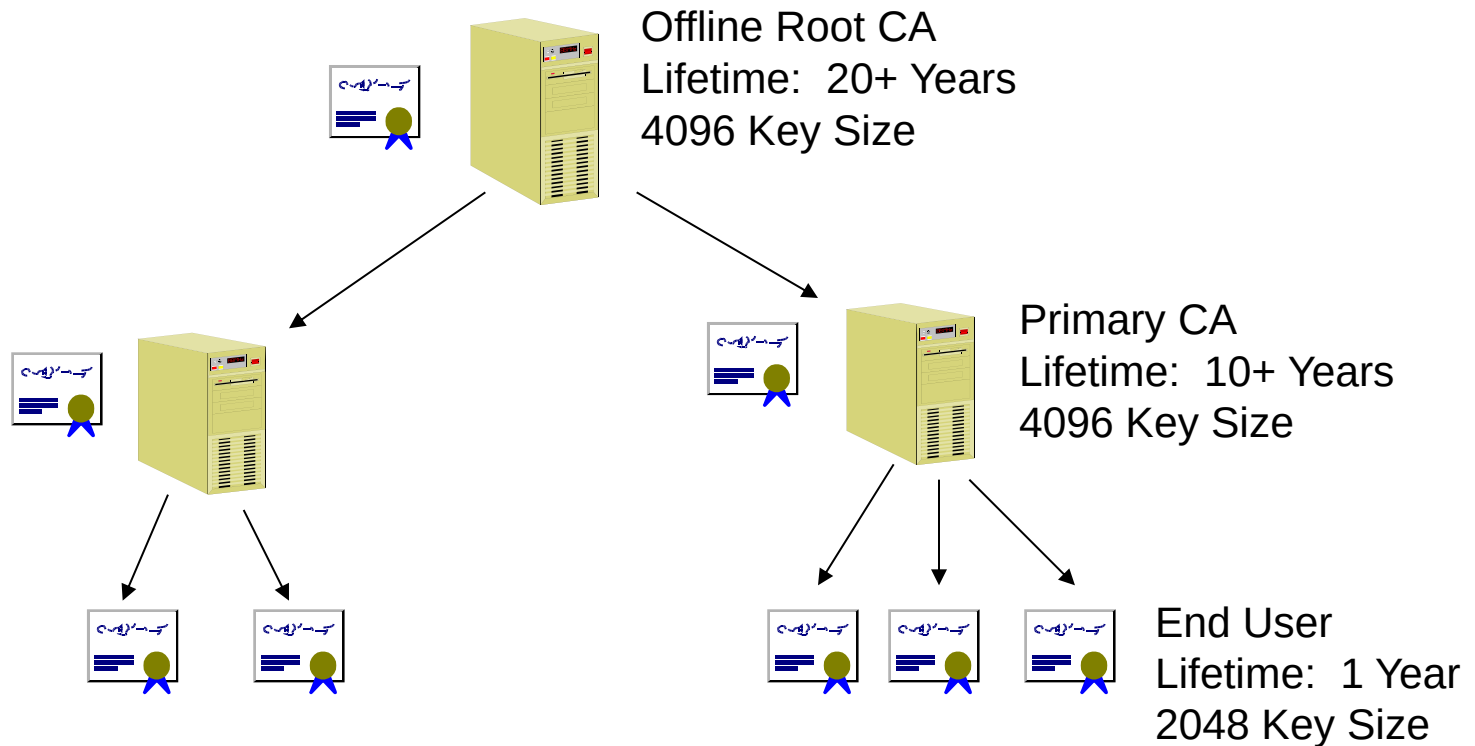
Aspecte privind implementarea unui PKI organizațional

- Suport din partea managementului organizației
- Informarea (instruirea) utilizatorilor
- Infrastructura existentă
 - rețeaua de comunicații
 - încăperi speciale
- Managementul cheilor
 - HSM (nCipher, Chrysalis, Eracom, Spyryus)
 - smart card-uri
- Elaborarea politicilor și procedurilor (CP & CPS)
- Asigurarea interoperabilității cu alte organizații
- Expertiza tehnică
- Legislația în vigoare

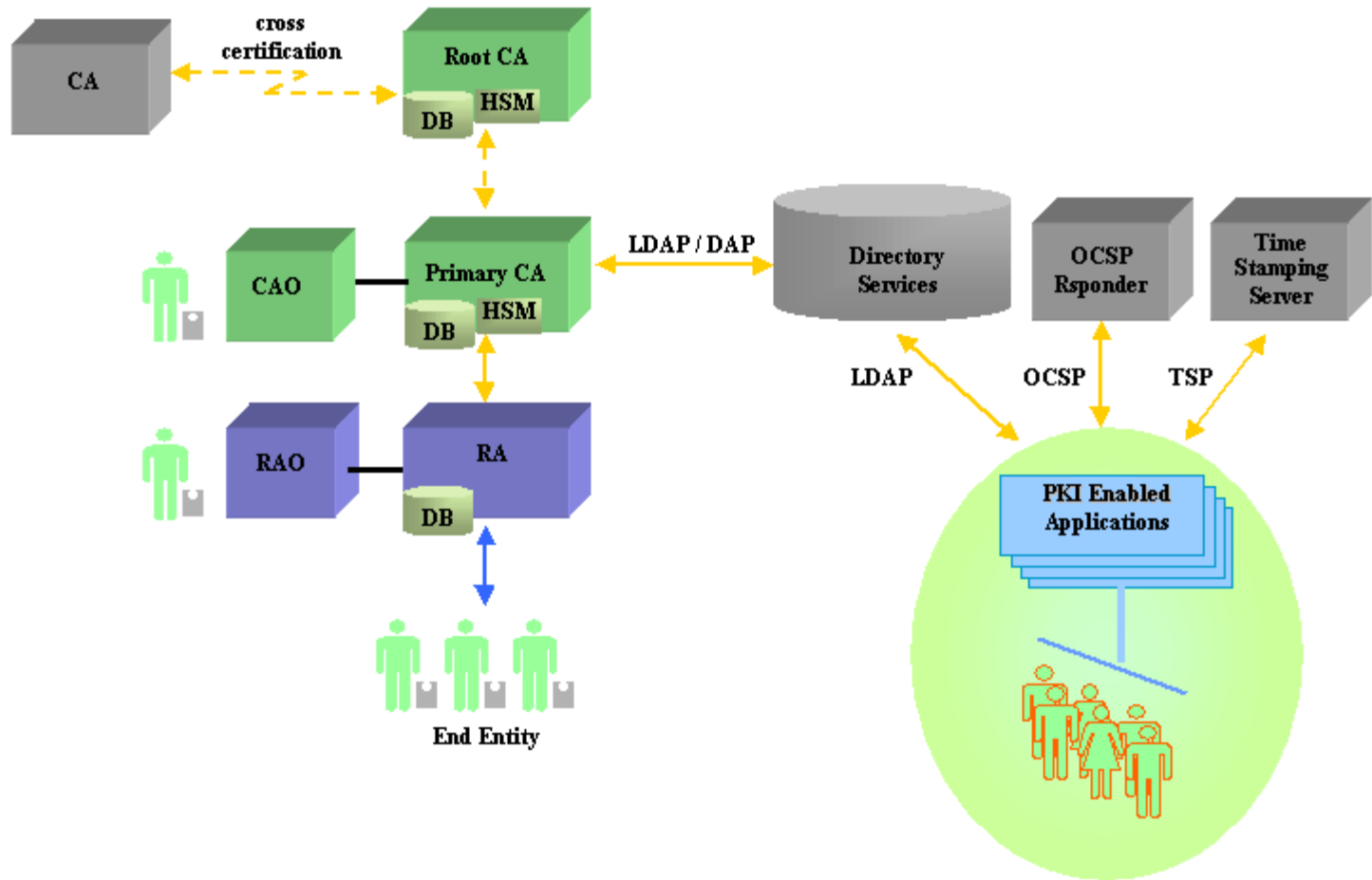
Etapele implementării unui PKI organizațional

- Analiza cerințelor
 - cerințele de business, politica de securitate, etc
 - inventarierea aplicațiilor PKI existente
- Definirea proiectului
 - plan de implementare
 - echipa de proiect
- Proiectarea arhitecturii
 - stabilirea topologiei
 - elaborarea politicilor și procedurilor
- Selectarea produselor
- Crearea unui pilot de test
- Implementarea infrastructurii
- Integrarea și testarea
- Instruirea personalului

Proiectarea topologiei PKI



Exemplu de arhitectura PKI



Furnizori de soluții PKI

- Entrust
- PrimeKey EJBCA
- Microsoft Certificate Services
 - Windows Server 2000 / 2003 / 2008 / 2012 / 2016
- Managed PKI Services (outsourcing)
 - GlobalSign

